

Security Analysis Report

Target Domain Audit

<https://kietgroup.com>

Generated on: April 24, 2026

Executive Summary

Security Score: **56/100 - Critical (F)**

This report provides a comprehensive security analysis of HTTP response headers for <https://kietgroup.com>. The scan identified potential vulnerabilities related to missing or misconfigured security headers.

Critical Issues: 2	Warnings: 2	Passed Checks: 2
--------------------	-------------	------------------

Detailed Technical Findings

[FAIL] Strict-Transport-Security

Severity: High
Description: Missing security header.
Recommendation: Configure HSTS to enforce HTTPS connections.
Recommended Value: 'max-age=63072000; includeSubDomains; preload'
Impact: Mitigates Man-in-the-Middle (MitM) attacks and cookie hijacking.

[FAIL] Content-Security-Policy

Severity: High
Description: Missing security header.
Recommendation: Implement a CSP to control resources the user agent is allowed to load.
Start with: "default-src 'self'; script-src 'self' https://trusted.input; object-src 'none';"
Impact: Prevents Cross-Site Scripting (XSS) and data injection attacks.

[WARN] X-Frame-Options

Severity: Medium
Description: Missing security header.

Recommendation: Protect against Clickjacking.

Recommended Value: 'DENY' or 'SAMEORIGIN'

Impact: Prevents the site from being embedded in iframes on malicious sites.

[WARN] X-Content-Type-Options

Severity: Medium

Description: Missing security header.

Recommendation: Prevent MIME-sniffing.

Recommended Value: 'nosniff'

Impact: Forces the browser to strictly follow the declared Content-Type.

[INFO] Referrer-Policy

Severity: Low

Description: Missing security header.

Recommendation: Control how much referrer information is sent.

Recommended Value: 'strict-origin-when-cross-origin'

Impact: Protects user privacy and prevents leakage of sensitive URL tokens.

[INFO] Permissions-Policy

Severity: Info

Description: Missing security header.

Recommendation: Restrict access to powerful browser features.

Recommended Value: "geolocation=(), microphone=(), camera=()"

Impact: Reduces the attack surface by disabling unused browser APIs.

[INFO] Cross-Origin-Opener-Policy

Severity: Info

Description: Missing security header.

Recommendation: Isolate your browsing context.

Recommended Value: 'same-origin'

Impact: Prevents other tabs from accessing your window object (Spectre mitigation).

[INFO] Cross-Origin-Resource-Policy

Severity: Info

Description: Missing security header.

Recommendation: Control who can read your resources.

Recommended Value: 'same-origin'

Impact: Prevents cross-origin reads of sensitive resources.

[INFO] Cross-Origin-Embedder-Policy

Severity: Info

Description: Missing security header.

Recommendation: Prevent loading cross-origin resources that don't opt-in.

Recommended Value: 'require-corp'

Impact: Enables high-performance features by ensuring environment isolation.

[INFO] Upgrade-Insecure-Requests

Severity: Low

Description: Missing security header.

Recommendation: Upgrade HTTP to HTTPS.

Recommended Value: '1'

Impact: Reduces mixed content issues.

[INFO] Cache-Control

Severity: Low

Description: Missing security header.

Recommendation: Prevent sensitive data caching.

Recommended Value: 'no-store, max-age=0' for sensitive pages.

Impact: Ensures privacy by keeping data off disk and proxy caches.

[INFO] Clear-Site-Data

Severity: Low

Description: Missing security header.

Recommendation: Clear browser data on logout.

Recommended Value: "'cache', 'cookies', 'storage'"

Impact: Ensures session cleanup and privacy.

[PASS] Server

Configured Value: Present

[PASS] X-Powered-By

Configured Value: Present

[INFO] X-AspNet-Version

Severity: Info

Description: Missing security header.

Recommendation: Information Disclosure Header.

Recommendation: Remove this header.

Impact: Hides .NET version info.

OWASP Compliance Mapping

Header	OWASP Ref	Requirement
Strict-Transport-Security	N/A	N/A
Content-Security-Policy	N/A	N/A
X-Frame-Options	N/A	N/A
X-Content-Type-Options	N/A	N/A
Referrer-Policy	N/A	N/A
Permissions-Policy	N/A	N/A
Cross-Origin-Opener-Policy	N/A	N/A
Cross-Origin-Resource-Policy	N/A	N/A
Cross-Origin-Embedder-Policy	N/A	N/A
Upgrade-Insecure-Requests	N/A	N/A
Cache-Control	N/A	N/A
Clear-Site-Data	N/A	N/A
Server	N/A	N/A
X-Powered-By	N/A	N/A
X-AspNet-Version	N/A	N/A